

Boas práticas de governança de dados

Projeto Kenzie 360 · Item 3 do escopo · MBA Engenharia de Dados · Mackenzie

Grupo: Ilan David Schapira · Giovanna Caetano Protti · Jonathas Borges

11/09/2026

1. O que o escopo pede, e o que este documento é

O escopo do Mackenzie trata arquitetura e governança como um bloco só, e define governança em uma frase:

"Aplicar princípios de segurança, metadados, qualidade e LGPD."

Este documento existe porque esses quatro princípios **já estão implementados no Kenzie 360**, mas espalhados por seis documentos e dois repositórios. Quem lê a entrega não consegue enxergar isso de uma vez.

Não há nada novo aqui. É consolidação, com o caminho para o código de cada controle. E, na Seção 7, a lista honesta do que está apenas desenhado — porque um documento de governança que só lista acertos não é documento de governança, é peça de marketing.

2. Segurança

Acesso

O princípio aplicado é o de **menor privilégio por camada**. O acesso à bronze é o mais restrito dos três: quem consulta a silver não precisa ver o texto original, e a silver já entrega a versão com PII tratada.

Os papéis foram concedidos individualmente, um a um, conforme a necessidade apareceu — não em bloco:

PAPEL	PARA QUÊ
<code>bigquery.jobUser</code>	rodar consultas
<code>bigquery.dataEditor</code>	escrever nas camadas
<code>serviceusage.serviceUsageConsumer</code>	usar as APIs do projeto
<code>storage.objectAdmin</code> · <code>storage.bucketViewer</code>	ler e escrever no bucket RAW

O registro de cada concessão, com o erro que a motivou, está em `Sprint4_Status.md`. **Isso é trilha de auditoria:** não se sabe apenas quem tem acesso, mas por que ganhou.

Autenticação da esteira

Workload Identity Federation, sem chave de service account. Não existe credencial de longa duração dentro do GitHub para vazar: o GCP confia numa identidade emitida pelo próprio GitHub, e apenas para este repositório.

O e-mail da service account aparece no código de propósito. Ele é **identificador, não segredo** — e como não há chave associada, publicá-lo não cria exposição. A decisão está registrada.

O bucket RAW

Configurado por Terraform (`infra/modules/data-lake/main.tf`), com quatro proteções:

CONFIGURAÇÃO	EFEITO
<code>public_access_prevention = "enforced"</code>	ninguém consegue tornar o bucket público, nem por engano
<code>uniform_bucket_level_access = true</code>	uma política só para o bucket, sem permissão por objeto
<code>versioning enabled</code>	sobrescrever um arquivo não perde a versão anterior
<code>force_destroy = false</code>	apagar o bucket exige um passo extra deliberado

O repositório é público

`github.com/MACK-Hand-on/MACK` . Isso impõe disciplina permanente, não uma revisão única:

- `.gitignore` exclui `*.tfstate` , `*-key.json` , `*credentials*.json` , `service-account*.json` , `.env` e `*.pem`
- sete ocorrências de caminho pessoal foram substituídas por `<seu-usuario>` antes do primeiro push
- varredura de segredos repetida a cada PR — a de 10/09 cobriu 124 arquivos
- **o nome do banco não é citado em nenhum artefato**

Custo como controle de segurança

Orçamento de US\$ 20/mês com alertas em 10%, 50% e 90%. Consumo real: 0,543 GiB de armazenamento (5,4% da franquia) e ~380 MB de consulta (0,04%). Um custo que dispara é sintoma — de consulta mal escrita, de laço infinito ou de acesso indevido.

3. Metadados

Linhagem

Toda linha da bronze carrega duas colunas que não vêm da origem:

COLUNA	O QUE REGISTRA
<code>_ingestion_ts</code>	quando este registro entrou
<code>_source_file</code>	de qual arquivo do Cloud Storage veio

Sem elas não se prova a origem de um registro — e **provar origem é metade do trabalho de governança em ambiente bancário**. Hoje elas registram, por exemplo, que a base atual veio do arquivo `_v8.csv` , e não da v7.

Os arquivos no bucket são versionados por data (`bronze/AAAAMMDD/`), o que fecha a cadeia: do arquivo ao registro, e do registro ao arquivo.

Catálogo

A camada gold tem **10 objetos, cada um documentado com a pergunta de negócio que responde e o achado da EDA que o justifica** — nenhum foi criado por completude:

VIEW	PERGUNTA	ACHADO QUE A JUSTIFICA
<code>vw_autonomia_por_tipo_demanda</code>	Por que o bot resolve pouco?	45,9% → 20,9%
<code>vw_funil_e_modos_de_falha</code>	Onde o atendimento vaza?	dois modos de falha
<code>vw_espiral_recorrencia</code>	Quem insiste é pior atendido?	29,9% → 15,4%
<code>vw_jornada_sentimento</code>	Onde o cliente se frustra?	vale no 3º quinto
(e outras seis)		

Um catálogo que explica **por que** um objeto existe vale mais que um que lista tipos de coluna.

O dicionário de dados das duas tabelas está na Seção 4 do Briefing Consolidado. Os recursos de infraestrutura carregam rótulos (`projeto` , `ambiente` , `camada`) e descrição, aplicados por Terraform.

Definição única de métrica

Duas decisões sustentam isso:

A gold é feita de views, não de uma tabela grande. A definição de cada métrica vive em um lugar só. Foi testado na prática: corrigir um denominador na view acertou o painel sem que ninguém editasse o painel.

Existe uma fonte única da verdade para os números do modelo. O `Numeros_Oficiais_Modelo13.md` declara: *"qualquer documento do projeto que discorde desta tabela está desatualizado."* Isso transformou conflito de versão em problema resolvível — e foi o que permitiu, em 10/09, encontrar e corrigir um documento da entrega que ainda trazia números de uma versão anterior do modelo.

4. Qualidade

Na ingestão

Schema explícito, nunca autodetecção. Três motivos, todos descobertos na prática:

1. O CSV começa com BOM. Com autodetecção, a marca invisível gruda no nome da primeira coluna.
2. Autodetecção adivinha tipos, e a bronze exige STRING por definição.
3. **Schema explícito falha alto** se a origem mudar de formato — e falhar alto é desejável numa camada de ingestão.

O detalhe que quase corrompeu a carga: 4.361 linhas de `atendimentos` e 4.842 de `mensagens` têm ponto e vírgula **dentro** do texto — o mesmo caractere usado como separador. Vêm protegidas por aspas, e a carga só

funciona porque declara `quote_character='''`. Sem isso, os registros quebrariam em colunas a mais, **silenciosamente, sem erro**.

Na transformação

CONTROLE	COMO
Conversão segura	<code>SAFE_CAST</code> e <code>SAFE.PARSE_DATETIME</code> — um valor inesperado vira NULL e aparece na validação, em vez de derrubar a carga
Deduplicação	por chave de negócio (<code>id_conversa</code> ; <code>id_conversa</code> + <code>ordem</code>), prevalecendo a ingestão mais recente
Contagens de controle	36.000 atendimentos e 405.073 mensagens. Se a carga divergir, algo deu errado
QA do gerador	<code>4_gerador_da_base/qa_dataset.py</code>

No modelo

Uma lista de 18 colunas proibidas, com aborto fatal. O `08_modelo_estagio1.py` carrega a lista e **para com erro** se alguma chegar ao conjunto de treino. A regra que a define está escrita: *uma feature só é legal se o valor estiver disponível no instante em que o modelo precisa decidir*.

Separação treino/teste por cliente, com verificação explícita de zero clientes em comum.

Medir o teto antes de treinar, com a regra: *"se a acurácia vier muito acima do teto calculado, não comemore — procure o vazamento."*

Na operação

CONTROLE	ONDE
Monitor de deriva que se autodiagnostica quando dispara	<code>10_lote_novo.py</code>
Conferência da distribuição depois de gravar na gold, com aviso se divergir	<code>11_</code> e <code>13_</code>
Recusa de empacotar notebook não executado	<code>12_</code>
Custo de consulta medido: 47 MB para as dez views, 0,004% da franquia	registrado

O controle humano, que valeu mais que todos

"Número que não rodamos é número que não defendemos."

Virou regra do projeto: nenhum número entra em entrega sem ter sido executado por alguém que não escreveu o código. Na prática, o modelo foi executado em três máquinas diferentes, com resultados batendo na terceira casa decimal.

5. LGPD e privacidade

Minimização por construção

A base é **100% sintética** — nunca deve ser descrita como dado real anonimizado.

E o gerador não produz dado pessoal para depois esconder. Ele simula o comportamento real (o cliente digita CPF, telefone, e-mail e número de conta no meio da conversa) e aplica o mascaramento **antes de persistir**: o valor bruto nunca chega ao arquivo, só o marcador `[CPF]`, `[TELEFONE]`, `[EMAIL]`, `[CONTA]`.

O resultado é uma base com o mesmo teor e completude de um log real, **descaracterizada por design**. É minimização de dados no sentido literal: o dado sensível não existe em nenhum ponto do ciclo.

A rede de segurança

A transição bronze → silver aplica regex de PII sobre o texto livre e marca com a coluna `pii_remascarada` as linhas em que a regra agiu.

Na base atual essa regra não encontra nada — os dados já nascem mascarados. Ela permanece porque em produção a origem é um export real, onde essa garantia não existe. É rede de segurança, e o custo de mantê-la é zero.

Telefone ficou deliberadamente de fora da regex. O padrão colide com valores monetários e números de protocolo, e **um falso positivo destrói dado legítimo**. A decisão está registrada com o motivo — é o tipo de escolha que, sem registro, parece esquecimento.

Separação de responsabilidade entre camadas

A bronze preserva o texto como veio; a silver entrega a versão tratada. **O acesso à bronze é o mais restrito** — quem consulta a silver não precisa ver o original. É a mesma lógica de um ambiente bancário real.

Retenção

O bucket RAW tem regra de expurgo automático em **365 dias**, aplicada por Terraform. Dado cru não fica guardado para sempre por inércia.

O material real do banco fica fora

O relatório de oportunidades perdidas, os prints da plataforma de atendimento e o print do fluxo do WhatsApp **informaram o entendimento do problema e não entraram** no repositório nem na entrega acadêmica. Mecânicas de atendimento se descrevem em texto, nunca como imagem de tela.

O argumento de LGPD by design depende disso. Uma base sintética perde o sentido se material real entra pela porta de trás.

6. Os controles funcionaram — a prova são os erros encontrados

Um controle que nunca pega nada não foi testado. Estes pegaram:

ERRO	COMO FOI ENCONTRADO	CONSEQUÊNCIA
Taxa de falha do humano inflada 2,01× (32,0% → 15,9%)	denominador excluía três em cada cinco casos resolvidos	duas conclusões retratadas , inclusive "Cartões é a pior área" ($X^2 = 14,86$, gl = 8, p = 0,062 — ruído amostral)
Classificador com 99,99%	revisão externa perguntou como; o grupo foi medir	resultado despromovido a diagnóstico da base
AUC 0,7039 reportado	população incluía 4.958 conversas que nunca geram atendimento	corrigido para 0,667; duas implementações convergindo
Quatro erros de reprodutibilidade	pipeline executada em outra máquina	caminhos absolutos e dependências corrigidos
Notebook sobrescrevendo o insumo da gold	revisão antes da execução	saída renomeada; o script de carga passou a recusar o arquivo errado
Usuário real do Windows num guia da entrega	varredura antes de fechar o pacote	substituído por <code><seu-usuario></code>

As retratações são o item mais importante desta lista. Duas conclusões publicadas foram derrubadas por medição e estão registradas como derrubadas, não apagadas. Governança de dados inclui **gestão de incidente de qualidade** — e um projeto que retrata conclusão própria demonstra isso melhor do que qualquer política escrita.

7. Desvios declarados, e o que está apenas desenhado

7.1 Três desvios da própria regra de features

O `Features_e_Vazamento.md`, escrito antes de qualquer treino, definiu as colunas permitidas. O modelo final de 13 variáveis **desvia dele em três pontos**:

DESVIO	O QUE A REGRA DIZIA	O QUE O MODELO FAZ	IMPACTO MEDIDO
<code>arquetipo</code>	"É construção do gerador, não um campo que exista na operação real. Não usar."	usa	≈ 0 no drop-one-out
<code>produto_relacionado</code>	listada como derivada de <code>categoria_assunto</code>	usa	≈ 0 no drop-one-out
<code>categoria_assunto</code>	deveria entrar como categoria prevista pelo estágio 1, não como valor verdadeiro	usa o valor verdadeiro	é a variável essencial (−0,0684)

O que isso significa, com honestidade:

Nenhum dos três é vazamento do desfecho — o modelo não vê o resultado da conversa. São problemas de **portabilidade** e de **disciplina de encadeamento**, não de validade estatística.

E o teste de importância resolve os dois primeiros: `arquetipo` e `produto_relacionado` contribuem **zero**. Removê-los não muda o AUC. Ou seja, **o resultado não depende deles** — o que é a melhor resposta possível para a pergunta.

O terceiro é o que mais merece atenção. Em produção só existe a categoria prevista, e a versão honesta do modelo deveria usá-la. O próprio documento antecipou isso: *"como o estágio 1 tem teto de 100%, a diferença numérica será pequena — mas a disciplina precisa estar no código, e a banca pode perguntar."* A diferença é pequena, mas a disciplina não está no código. **Fica declarado como limitação, não como detalhe.**

Também vale corrigir: o `Features_e_Vazamento.md` traz baseline de 74,77% e teto de AUC 0,750. Os dois foram superados — a população foi depurada e o teto recalculado a partir da fórmula do gerador. **Valem 70,5% e 0,6736**, conforme `Numeros_Oficiais_Modelo13.md`.

7.2 O que está desenhado e não implementado

ITEM	ESTADO
Policy tags / classificação formal de sensibilidade	desenhada (Dataplex avaliado e substituído por mascaramento em SQL por custo). Hoje a sensibilidade é tratada por camada e por regex, não por rótulo formal
Ferramenta de catálogo	o catálogo existe como documentação, não como metadado consultável
Ambiente de produção	estruturado em Terraform, com valores de exemplo. Não provisionado
Retreino automático	ciclo desenhado e gatilho definido; execução automática fora do escopo
Agendamento da carga incremental	a carga foi demonstrada; o agendamento (Cloud Scheduler + Cloud Run Jobs) está desenhado
Testes de qualidade na esteira	a esteira valida infraestrutura (<code>fmt</code> , <code>validate</code> , <code>tflint</code> , <code>Checkov</code>), não dado

7.3 A lacuna que o próprio projeto revelou

Não existe dono da governança. Os controles das seções 2 a 5 estão implementados, mas **distribuídos entre três pessoas**, cada um nascido da necessidade de quem estava com a mão no problema. Nenhuma pessoa responde pelo conjunto.

Em ambiente bancário esse papel é obrigatório. Foi assim que descobrimos que o Kenzie 360 exige um sexto perfil que ninguém do grupo ocupou — registrado no item 5, *Trilhas de carreira*.

8. Resumo para a banca

PRINCÍPIO	IMPLEMENTADO	ONDE
Segurança	menor privilégio por camada · WIF sem chave · bucket sem acesso público possível · varredura de segredo a cada PR · orçamento com alerta	<code>infra/</code> , <code>Setup_GCP_Kenzie360.md</code>
Metadados	linhagem por registro · catálogo com a pergunta de cada objeto · dicionário de dados · rótulos por Terraform · fonte única da verdade para métricas	<code>Modelagem_Camadas_BigQuery.md</code> , <code>Numeros_Oficiais_Modelo13.md</code>
Qualidade	schema explícito que falha alto · conversão segura · deduplicação por chave de negócio · contagens de controle · 18 colunas proibidas com aborto fatal · monitor de deriva · execução independente obrigatória	<code>3_pipeline/</code> , <code>Features_e_Vazamento.md</code>
LGPD	base sintética · mascaramento antes de persistir · rede de segurança em regex · acesso restrito à bronze · retenção de 365 dias · material real do banco fora da entrega	<code>4_gerador_da_base/</code> , <code>Modelagem_Camadas_BigQuery.md</code>

A tese deste documento: governança não é um capítulo escrito ao fim do projeto — são decisões tomadas no meio do caminho, cada uma com um motivo registrado. O que prova que funcionaram não é a lista de controles: são os **seis erros que eles pegaram** e as **duas conclusões que o projeto retratou sobre si mesmo**.